Vulnerability Assessment Report

DownUnderNewsz - Penetration Test Report

DownUnderNewsz
22 Arthur St
Fairfield VIC 3078, Australia

Flinders University
Sturt Road, Bedford Park SA 5042

September 19, 2026

Report Version: 1.1

CONFIDENTIAL

Table of Contents

List of Figures 4

1 Document Control 5

1.1 Team 5

1.2 List of Changes 5

2 Executive Summary 6

2.1 Overview 6

2.2 Identified Vulnerabilities 7

3 Methodology 8

3.1 Objective 8

3.2 Scope 8

3.3 User Accounts and Permissions 9

4 Findings 10

H1: Stored Cross-Site Scripting (XSS) via Article Content 10

M1: Missing Cross-Site Request Forgery (CSRF) Protection 11

M2: Anonymous FTP Read Access to Media Server 12

M3: Sensitive Information Disclosure via Unauthenticated API 13

M4: Malicious File Upload — HTML Served as text/html (Stored XSS) 14

L1: Session Cookie Missing Secure and SameSite Flags 15

I1: Missing Security Headers 16

I2: TLS Certificate Hostname Mismatch on www Subdomain 17

I3: Weak and Shared Administrator/User Credentials 18

5 Disclaimer 19

A Appendix 20

A.1 Static Appendix Section 20

A.2 Limitations & Constraints 20

A.3 Coverage Summary 20

A.4 Severity Classification 20

List of Figures

Figure 1 - Distribution of identified vulnerabilities 7

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Initial report release	Sep 19, 2026
1.1	Corrected CVSS/severity consistency: Sensitive Information Disclosure via Unauthenticated API re-rated to Medium; Weak and Shared Administrator/ User Credentials re-rated to Low with CVSS removed.	Sep 19, 2026

2 Executive Summary

2.1 Overview

Overview

DownUnderNewsz — an independent Australian online news publication — engaged ClawSec to perform an authorized, single-day vulnerability assessment of its public-facing news platform (thedownundernews.online and media.thedownundernews.online). Testing was completed on 19 September 2026 using non-destructive techniques throughout.

The assessment identified **9 findings**: 1 high, 4 medium, 3 low, and 1 informational. No critical-severity issues were found.

What this means for the business

The most important issue is **stored cross-site scripting (XSS)**. The article editor does not filter out embedded scripts, so a low-privileged user (a "writer") could inject code that runs in the browser of every visitor — and, because the site also lacks CSRF protection, this could ultimately lead to a full administrative takeover. This should be treated as the top priority.

Several supporting issues further weaken the platform: the media server allows anonymous FTP downloads of media assets, administrator identity is exposed through the public API, session cookies lack important security flags, weak/shared credentials are in use, the www certificate is misconfigured, and standard security headers are absent. On the positive side, role-based access control held up well — the writer role was correctly denied administrative functions.

Findings summary

Severity	Count
Critical	0
High	1
Medium	4
Low	3
Informational	1

Top recommendations

1. Sanitize article content (and uploaded HTML) so scripts cannot run in visitors' browsers (immediate priority).
2. Add CSRF protection and set Secure/SameSite flags on the session cookie.
3. Disable anonymous FTP on the media server and restrict uploads to safe file types.

4. Remove internal author details (email, username, role) from public API responses.
5. Reissue the TLS certificate to cover www, and add standard security headers.

A detailed technical description and remediation guidance for each finding is provided in the body of this report.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
H1	7.6	Stored Cross-Site Scripting (XSS) via Article Content	10
M1	6.5	Missing Cross-Site Request Forgery (CSRF) Protection	11
M2	5.3	Anonymous FTP Read Access to Media Server	12
M3	5.3	Sensitive Information Disclosure via Unauthenticated API	13
M4	4.6	Malicious File Upload — HTML Served as text/html (Stored XSS)	14
L1	3.1	Session Cookie Missing Secure and SameSite Flags	15
I1	0.0	Missing Security Headers	16
I2	0.0	TLS Certificate Hostname Mismatch on www Subdomain	17
I3	0.0	Weak and Shared Administrator/User Credentials	18

Vulnerability Overview

In the course of this penetration test **1 High**, **4 Medium**, **1 Low** and **3 Info** vulnerabilities were identified:

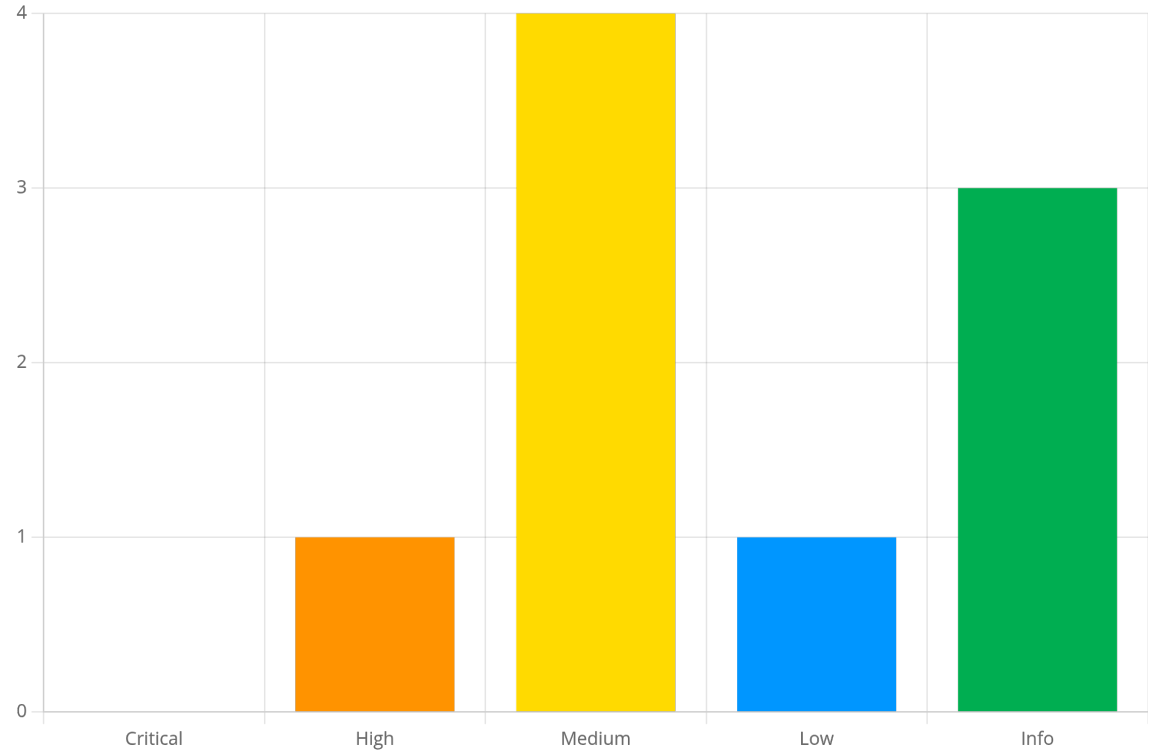


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

3.2 Scope

In-scope assets

Asset	Type	Technology
thedownundernews.online (apex + www)	Main news website / CMS	51.161.130.70 (OVH VPS) — nginx + Python/Flask news CMS, JSON API, admin panel
media.thedownundernews.online	Media storage	51.161.131.195 (OVH VPS) — nginx, anonymous FTP

Out of scope / excluded

The following were explicitly excluded: `thedownundernews.it.com` (no DNS resolution), and all third-party infrastructure (OVH hosting, Spaceship registrar/DNS/MX, jsdelivr/Google Fonts CDNs, Let's Encrypt).

Engagement type

Authorized, full-scope vulnerability assessment of public-facing web assets. Single-day engagement (19 September 2026).

Methodology

Passive and light-active enumeration (DNS, WHOIS/RDAP, subdomain enumeration, certificate transparency, TLS inspection, HTTP header/content review), manual web-application security testing of the JSON API and admin panel, authenticated testing using business-owner-provided dummy accounts (admin/writer/editor), FTP service review, and TLS/security-header review. All testing was non-destructive throughout; no denial-of-service, no brute force/password spraying, and no social engineering were performed.

3.3 User Accounts and Permissions

The business owner provided three dummy test accounts (admin, writer, editor) for authorized authenticated testing of the admin panel and API. Credential values are intentionally omitted from this report.

4 Findings

H1: Stored Cross-Site Scripting (XSS) via Article Content	
Score	7.6 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:L/A:N
Target	https://thedownundernews.online/ (article create/edit, POST/PUT /api/admin/articles)
References	• OWASP Top 10 (2021) A03: Injection • CWE-79

Overview

Severity: High

The article editor stores raw, unsanitized HTML and renders it directly on the public site. Any authenticated user with article-write privileges (writer, editor, or admin) can inject JavaScript that executes in the browser of every visitor who views the article.

Details

The article "content" field is accepted verbatim by `POST /api/admin/articles` and `PUT /api/admin/articles/{id}` with no HTML sanitization. During testing, a test article (id 17, slug "clawsec-xss-9917") was created with content `<p>test</p><script>alert(document.domain)</script>` and status "published". The server persisted the raw payload and the public page `https://thedownundernews.online/article/clawsec-xss-9917` rendered it unescaped inside `<div class="article-body prose">`. The lowest-privileged role (writer) is able to create articles, so this is achievable with minimal privilege. Because the application also lacks CSRF protections (see the CSRF finding), the injected script can perform authenticated admin actions on behalf of a logged-in administrator who views the article, escalating to full CMS compromise. The test article was deleted after verification.

Recommendation

Sanitize article HTML server-side on input and/or output (e.g., Bleach or NH3 allowlist), disallow `<script>` and event-handler attributes, and consider rendering content with a strict Content-Security-Policy. Re-validate the writer/editor role's ability to publish before publication.

M1: Missing Cross-Site Request Forgery (CSRF) Protection	
Score	6.5 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N
Target	https://thedownundernews.online/ (admin login, article CRUD, user management, media upload/delete, comment form)
References	• OWASP Top 10 (2021) A01: Broken Access Control • CWE-352

Overview

Severity: Medium

State-changing endpoints (login, article create/edit/delete, user create/update/delete/reset-password, media upload/delete, and public comment submission) are protected only by the session cookie, with no CSRF tokens, and the session cookie lacks a SameSite attribute.

Details

No CSRF token or Origin/Referer validation is present on any observed form or JSON endpoint. The session is carried in an "access_token_cookie" (JWT) cookie with no SameSite attribute. An attacker who lures an authenticated user (e.g., an admin) to a malicious page can issue forged state-changing requests (e.g., creating a new admin user, deleting content) using the victim's cookie. Modern browsers default to SameSite=Lax, which partially mitigates cross-site POSTs, but this reliance is fragile and does not cover all request types/browsers.

Recommendation

Implement CSRF tokens on all state-changing requests (or enforce SameSite=Strict/Lax explicitly plus Origin/Referer validation), and use the X-CSRF-Token pattern for the JSON API.

M2: Anonymous FTP Read Access to Media Server	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	media.thedownundernews.online (51.161.131.195) — FTP/21
References	• CWE-276 • CWE-284

Overview

Severity: Medium

The media server's FTP service (port 21) permits anonymous, unauthenticated directory listing and file download, exposing uploaded media assets.

Details

An anonymous FTP connection to media.thedownundernews.online successfully listed and downloaded media files (two PNG images, a PDF, and an HTML file) without credentials. An attempted anonymous upload returned FTP 553 (denied), indicating the anonymous account is read-only. Nonetheless, media assets intended to be managed through the authenticated application are exposed to anyone on the internet.

Recommendation

Disable anonymous FTP, require authentication with strong credentials, and restrict the FTP service (or replace it with SFTP/HTTPS upload with access controls).

M3: Sensitive Information Disclosure via Unauthenticated API	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	https://thedownundernews.online/ (GET /api/articles, /api/articles/{slug}, /api/search)
References	• CWE-200 • OWASP Top 10 (2021) A01: Broken Access Control

Overview

Severity: Medium

Public, unauthenticated API endpoints return full author objects including internal usernames and email addresses.

Details

The unauthenticated endpoints /api/articles, /api/articles/{slug}, and /api/search embed a full nested "author" object for every article, exposing the administrator's username ("admin"), email ("admin@thedownundernews.it.com"), role, account status, and creation timestamps to anyone. This aids targeting, phishing, and account enumeration.

Recommendation

Remove internal author fields (email, username, role, timestamps) from public responses, or return only a public display name.

M4: Malicious File Upload — HTML Served as text/html (Stored XSS)	
Score	4.6 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N
Target	• https://thedownundernews.online/ (POST /api/admin/media/upload) • https://media.thedownundernews.online/
References	• OWASP Top 10 (2021) A03: Injection • CWE-434

Overview

Severity: Medium

The media library accepts HTML file uploads and the media host serves them with Content-Type: text/html and no anti-sniffing or CSP protections, so uploaded files render as executable web pages.

Details

An uploaded file (dunhtml7731.html) stored at https://media.thedownundernews.online/images/37550846eae5457d93ddd8e1d2faeaca.html is served with Content-Type: text/html and contains `<script>alert(document.domain)</script>`. The response includes no X-Content-Type-Options: nosniff, no Content-Disposition, and no Content-Security-Policy. Any authenticated user with media-upload access (writer role included) can host arbitrary JavaScript/HTML on the media subdomain, enabling stored XSS, phishing, or content injection. The upload endpoint itself correctly requires authentication (401 when unauthenticated).

Recommendation

Restrict uploads to a safe allowlist of MIME types (images, PDF), reject or sanitize HTML, serve uploaded files with X-Content-Type-Options: nosniff and Content-Disposition: attachment, and serve media from a domain isolated from the application.

L1: Session Cookie Missing Secure and SameSite Flags	
Score	3.1 (Low)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N
Target	https://thedownundernews.online/ (login)
References	• OWASP Secure Cookie guidance • CWE-614 • CWE-1004

Overview

Severity: Low

The session cookie (access_token_cookie) is issued with HttpOnly but without the Secure and SameSite attributes.

Details

On successful login the server sets `access_token_cookie=<JWT>; HttpOnly; Path=/`. The cookie lacks the Secure flag (so it would be transmitted over any plaintext HTTP connection if the site were ever served over HTTP) and lacks SameSite. Combined with the absence of CSRF tokens, this weakens the session's protections.

Recommendation

Set the Secure flag (and HSTS) so cookies only travel over HTTPS, and set SameSite=Lax (or Strict) explicitly.

I1: Missing Security Headers	
Score	0.0 (Info)
Vector string	N/A
Target	https://thedownundernews.online/ (all pages)
References	• OWASP Secure Headers Project • CWE-693

Overview

Severity: Info

HTTP responses omit modern security headers, weakening the browser's defense-in-depth.

Details

Responses lack Content-Security-Policy, X-Frame-Options/frame-ancestors, X-Content-Type-Options, Strict-Transport-Security, and Referrer-Policy. This enables clickjacking and content-type sniffing, and leaves no CSP to constrain injected scripts (compounding the XSS findings).

Recommendation

Add a strict CSP, X-Content-Type-Options: nosniff, X-Frame-Options: DENY (or frame-ancestors), Strict-Transport-Security, and Referrer-Policy headers.

I2: TLS Certificate Hostname Mismatch on www Subdomain	
Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/
References	CWE-295

Overview

Severity: Low

The TLS certificate served for www.thedownundernews.online does not include "www" in its Subject Alternative Names, causing browser certificate warnings.

Details

The certificate presented for www.thedownundernews.online has CN/SAN of "thedownundernews.online" only (issued by Let's Encrypt). Accessing the site via "www" triggers a hostname-mismatch warning, which erodes user trust and can train users to bypass warnings.

Recommendation

Reissue the certificate to include both the apex and www (or redirect www to apex over a correctly-issued certificate).

I3: Weak and Shared Administrator/User Credentials	
Score	0.0 (Info)
Vector string	N/A
Target	https://thedownundernews.online/admin (admin, writer, editor accounts)
References	• CWE-521 • NIST SP 800-63B

Overview

Severity: Low

The provided accounts all use the same weak password, indicating no password complexity or uniqueness policy.

Details

The admin, writer, and editor accounts were all provisioned with the same short, easily-guessable password. While these are dummy accounts supplied for this assessment, they demonstrate a weak/shared-password posture; if real accounts follow the same pattern, a single weak credential would grant broad access. The login page also shows no rate-limiting or account-lockout indicators.

Recommendation

Enforce strong, unique passwords, enable multi-factor authentication for administrative accounts, and add account lockout/rate-limiting on login.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Limitations & Constraints

The following limitations applied to this engagement:

- The admin dashboard intermittently returned 504/slow responses under load.
- A small number of API paths timed out during light probing and were not exhaustively tested.
- No automated scanner was used (manual testing only).
- The referenced email domain `thedownundernews.it.com` does not resolve and was not assessed.
- Authenticated testing was limited to the three owner-provided dummy accounts (admin, writer, editor).

All testing was performed within the approved scope and without destructive impact.

A.3 Coverage Summary

The following surfaces were reviewed during the engagement:

- 2 origin IP addresses (51.161.130.70 and 51.161.131.195).
- 2 subdomains (apex/www and media).
- Approximately 12 web/API endpoints.
- The full admin panel (dashboard, articles, categories, media library, comments, users, profile).
- The FTP service on the media host.

A.4 Severity Classification

Findings are rated on the following scale:

Severity	Meaning
Critical	Immediate action required; can lead to full system compromise.
High	Serious issue that can compromise significant functionality or data.
Medium	Notable weakness requiring prompt remediation.
Low	Minor weakness that reduces defense-in-depth.
Informational	No direct exploitability; noted for awareness and hardening.

Where an explicit CVSS v3.1 vector was provided in the source findings, it is recorded on the finding. Findings without a CVSS vector are shown as "N/A" in the CVSS-driven scoring, while their assessed severity is stated in each finding and in the executive summary.